

Objectifs et mesures de sécurité de la norme ISO/ CEI 27002 : 2005 [A. Ben Mouloud, 2011]

A.5 Politique de sécurité		
A.5.1 Politique de sécurité de l'information		
<i>Objectif:</i> Apporter à la sécurité de l'information une orientation et un soutien de la part de la direction, conformément aux exigences métier et aux lois et règlements en vigueur		
A.5.1.1	Document de politique de sécurité de l'information	Mesure Un document de politique de sécurité de l'information doit être approuvé par la direction, puis publié et diffusé auprès de l'ensemble des salariés et des tiers concernés
A.5.1.2	Réexamen de la politique de sécurité de l'information	Mesure Pour garantir la pertinence, l'adéquation et l'efficacité de la politique de sécurité de l'information, la politique doit être réexaminée à intervalles fixés préalablement ou en cas de changements majeurs
A.6 Organisation de la sécurité de l'information		
A.6.1 Organisation interne		
<i>Objectif:</i> Gérer la sécurité de l'information au sein de l'organisme.		
A.6.1.1	Implication de la direction vis-à-vis de la sécurité de l'information	Mesure La direction doit soutenir activement la politique de sécurité au sein de l'organisme au moyen de directives claires, d'un engagement démontré, d'attribution de fonctions explicites et d'une reconnaissance des responsabilités liées à la sécurité de l'information
A.6.1.2	Coordination de la sécurité de l'information	Mesure Les activités relatives à la sécurité de l'information doivent être coordonnées par des intervenants ayant des fonctions et des rôles appropriés représentatifs des différentes parties de l'organisme
A.6.1.3	Attribution des responsabilités en matière de sécurité de l'information	Mesure Toutes les responsabilités en matière de sécurité de l'information doivent être définies clairement
A.6.1.4	Système d'autorisation concernant les moyens de traitement de l'information	Mesure Un système de gestion des autorisations doit être défini et mis en œuvre pour chaque nouveau moyen de traitement de l'information
A.6.1.5	Engagements de confidentialité	Mesure Les exigences en matière d'engagements de confidentialité ou de non-divulgaration, conformément aux besoins de l'organisme, doivent être identifiées et réexaminées régulièrement
A.6.1.6	Relations avec les autorités	Mesure Des relations appropriées doivent être mises en place avec les autorités compétentes

A.6.1.7	Relations avec des groupes de spécialistes	Mesure Des contacts appropriés doivent être entretenus avec des groupes de spécialistes, des forums spécialisés dans la sécurité et des associations professionnelles
A.6.1.8	Réexamen indépendant de la sécurité de l'information	Mesure Des réexamens réguliers et indépendants de l'approche retenue par l'organisme pour gérer et mettre en œuvre sa sécurité (c'est-à-dire le suivi des objectifs de sécurité, les politiques, les procédures et les processus relatifs à la sécurité de l'information) doivent être effectués ; de tels réexamens sont également nécessaires lorsque des changements importants sont intervenus dans la mise en œuvre de la sécurité
A.6.2 Tiers <i>Objectif:</i> Assurer la sécurité de l'information et des moyens de traitement de l'information appartenant à l'organisme et consultés, traités, communiqués ou gérés par des tiers		
A.6.2.1	Identification des risques provenant des tiers	Mesure Les risques pesant sur l'information et les moyens de traitement de l'organisme qui découlent d'activités impliquant des tiers doivent être identifiés, et des mesures appropriées doivent être mises en œuvre avant d'accorder des accès
A.6.2.2	La sécurité et les clients	Mesure Tous les besoins de sécurité doivent être traités avant d'accorder aux clients l'accès à l'information ou aux actifs de l'organisme
A.6.2.3	La sécurité dans les accords conclus avec des tiers	Mesure Les accords conclus avec des tiers qui portent sur l'accès, le traitement, la communication ou la gestion de l'information, ou des moyens de traitement de l'information de l'organisme, ou qui portent sur l'ajout de produits ou de services aux moyens de traitement de l'information, doivent couvrir l'ensemble des exigences applicables en matière de sécurité
A.7 Gestion des actifs		
A.7.1 Responsabilités relatives aux actifs <i>Objectif:</i> Mettre en place et maintenir une protection appropriée des actifs de l'organisme		
A.7.1.1	Inventaire des actifs	Mesure Tous les actifs doivent être clairement identifiés et un inventaire de tous les actifs importants doit être réalisé et géré
A.7.1.2	Propriété des actifs	Mesure La propriété de chaque information et des moyens de traitement de l'information doit être 'attribuée3) à une partie définie de

		l'organisme
A.7.1.3	Utilisation correcte des actifs	Mesure Des règles permettant l'utilisation correcte de l'information et des actifs associés aux moyens de traitement de l'information doivent être identifiées, documentées et mises en œuvre
A.7.2 Classification des informations <i>Objectif:</i> Garantir un niveau de protection approprié aux informations		
A.7.2.1	Lignes directrices pour la classification	Mesure Les informations doivent être classées en termes de valeur, d'exigences légales, de sensibilité et de criticité
A.7.2.2	Marquage et manipulation de l'information	Mesure Un ensemble approprié de procédures pour le marquage et la manipulation de l'information doit être élaboré et mis en œuvre conformément au plan de classification adopté par l'organisme
A.8 Sécurité liée aux ressources humaines		
A.8.1 Avant le recrutement <i>Objectif:</i> Garantir que les salariés, contractants et utilisateurs tiers connaissent leurs responsabilités et qu'ils conviennent pour les fonctions qui leur sont attribuées et réduire le risque de vol, de fraude ou de mauvais usage des équipements		
A.8.1.1	Rôles et responsabilités	Mesure Les rôles et responsabilités en matière de sécurité des salariés, contractants et utilisateurs tiers doivent être définis et documentés conformément à la politique de sécurité de l'information de l'organisme
A.8.1.2	Sélection	Mesure Qu'il s'agisse de postulants, de contractants ou d'utilisateurs tiers, les vérifications des informations concernant tous les candidats doivent être réalisées conformément aux lois, aux règlements et à l'éthique et doivent être proportionnelles aux exigences métier, à la classification des informations accessibles et aux risques identifiés
A.8.1.3	Conditions d'embauche	Mesure Dans le cadre de leurs obligations contractuelles, les salariés, contractants et utilisateurs tiers doivent se mettre d'accord sur les modalités du contrat d'embauche les liant et le signer. Ce contrat doit définir leurs responsabilités et celles de l'organisme quant à la sécurité de l'information
A.8.2 Pendant la durée du contrat <i>Objectif:</i> Veiller à ce que tous les salariés, contractants et utilisateurs tiers soient conscients des menaces pesant sur la sécurité de l'information, de leurs responsabilités financières ou autres, et disposent des éléments requis pour prendre en charge la politique de sécurité de		

l'organisme dans le cadre de leur activité normale et réduire le risque d'erreur humaine		
A.8.2.1	Responsabilités de la direction	Mesure La direction doit demander aux salariés, contractants et utilisateurs tiers d'appliquer les règles de sécurité conformément aux politiques et procédures établies de l'organisme
A.8.2.2	Sensibilisation, qualification et formations en matière de sécurité de l'information	Mesure L'ensemble des salariés d'un organisme et, le cas échéant, les contractants et utilisateurs tiers doivent suivre une formation adaptée sur la sensibilisation et doivent recevoir régulièrement les mises à jour des politiques et procédures de l'organisme, pertinentes pour leurs fonctions.
A.8.2.3	Processus disciplinaire	Mesure Un processus disciplinaire formel doit être élaboré pour les salariés ayant enfreint les règles de sécurité
A.8.3 Fin ou modification du contrat <i>Objectif:</i> Veiller à ce que les salariés, contractants et utilisateurs tiers quittent un organisme ou changent de poste selon une procédure définie		
A.8.3.1	Responsabilités en fin de contrat	Mesure Les responsabilités relatives aux fins ou aux modifications de contrats doivent être clairement définies et attribuées
A.8.3.2	Restitution des actifs	Mesure Tous les salariés, contractants et utilisateurs tiers doivent restituer la totalité des actifs de l'organisme qu'ils ont en leur possession à la fin de leur période d'emploi, contrat ou accord
A.8.3.3	Retrait des droits d'accès	Mesure Les droits d'accès de l'ensemble des salariés, contractants et utilisateurs tiers à l'information et aux moyens de traitement de l'information doivent être supprimés à la fin de leur période d'emploi, ou modifiés en cas de modification du contrat ou de l'accord
A.9 Sécurité physique et environnementale		
A.9.1 Zones sécurisées <i>Objectif:</i> Empêcher tout accès physique non autorisé, tout dommage ou intrusion dans les locaux ou portant sur les informations de l'organisme		
A.9.1.1	Périmètre de sécurité physique	Mesure Les zones contenant des informations et des moyens de traitement de l'information doivent être protégées par des périmètres de sécurité (obstacles tels que des murs, des portes avec un contrôle d'accès par cartes, ou des bureaux de réception avec personnel d'accueil)
A.9.1.2	Contrôles physiques des accès	Mesure Les zones sécurisées doivent être protégées par des contrôles à l'entrée adéquats pour s'assurer

		que seul le personnel habilité est admis
A.9.1.3	Sécurisation des bureaux, des salles et des équipements	Mesure Des mesures de sécurité physique doivent être conçues et appliquées pour les bureaux, les salles et les équipements
A.9.1.4	Protection contre les menaces extérieures et environnementales	Mesure Des mesures de protection physique contre les dommages causés par les incendies, les inondations, les tremblements de terre, les explosions, les troubles civils et autres formes de catastrophes naturelles ou de sinistres provoqués par l'homme, doivent être conçues et appliquées
A.9.1.5	Travail dans les zones sécurisées	Mesure Des mesures de protection physique et des directives pour le travail en zone sécurisée doivent être conçues et appliquées
A.9.1.6	Zones d'accès public, de livraison et de chargement	Mesure Les points d'accès tels que les zones de livraison/chargement et les autres points par lesquels des personnes non habilitées peuvent pénétrer dans les locaux doivent être contrôlés. Les points d'accès doivent également, si possible, être isolés des moyens de traitement de l'information, de façon à éviter les accès non autorisés
A.9.2 Sécurité du matériel <i>Objectif:</i> Empêcher la perte, l'endommagement, le vol ou la compromission des actifs et l'interruption des activités de l'organisme.		
A.9.2.1	Choix de l'emplacement et protection du matériel	Mesure Le matériel doit être situé et protégé de manière à réduire les risques de menaces et de dangers environnementaux et les possibilités d'accès non autorisé
A.9.2.2	Services généraux	Mesure Le matériel doit être protégé des coupures de courant et autres perturbations dues à une défaillance des services généraux.
A.9.2.3	Sécurité du câblage	Mesure Les câbles électriques ou de télécommunications transportant des données doivent être protégés contre toute interception d'information ou dommage
A.9.2.4	Maintenance du matériel	Mesure Le matériel doit être entretenu correctement pour garantir sa disponibilité permanente et son intégrité
A.9.2.5	Sécurité du matériel hors des locaux	Mesure La sécurité doit être appliquée au matériel utilisé hors des locaux de l'organisme en tenant compte des différents risques associés au travail hors site

A.9.2.6	Mise au rebut ou recyclage sécurisé(e) du matériel	Mesure Tout le matériel contenant des supports de stockage doit être vérifié pour s'assurer que toute donnée sensible a bien été supprimée et que tout logiciel sous licence a bien été désinstallé ou écrasé de façon sécurisée, avant sa mise au rebut
A.9.2.7	Sortie d'un actif	Mesure Un matériel, des informations ou des logiciels ne doivent pas être sortis des locaux de l'organisme sans autorisation préalable
A.10 Gestion de l'exploitation et des télécommunications		
A.10.1 Procédures et responsabilités liées à l'exploitation		
<i>Objectif:</i> Assurer l'exploitation correcte et sécurisée des moyens de traitement de l'information		
A.10.1.1	Procédures d'exploitation documentées	Mesure Les procédures d'exploitation doivent être documentées, tenues à jour et disponibles pour tous les utilisateurs concernés
A.10.1.2	Management des modifications	Mesure Les changements apportés aux systèmes et moyens de traitement de l'information doivent être contrôlés
A.10.1.3	Séparation des tâches	Mesure Les tâches et les domaines de responsabilité doivent être séparés pour réduire les occasions de modification ou de mauvais usage non autorisé(e) ou involontaire des actifs de l'organisme
A.10.1.4	Séparation des équipements de développement, d'essai et d'exploitation	Mesure Les équipements de développement, d'essai et d'exploitation doivent être séparés pour réduire les risques d'accès ou de changements non autorisés dans le système d'information en exploitation
A.10.2 Gestion de la prestation de service conclus avec un tiers		
<i>Objectif:</i> Mettre en œuvre et maintenir un niveau de sécurité de l'information et de service adéquat et conforme aux accords de prestation de service conclus avec un tiers		
A.10.2.1	Prestation de service	Mesure Il doit être assuré que les mesures de sécurité, les définitions du service et les niveaux de prestation prévus dans l'accord de prestation de service tiers sont mis en œuvre, appliqués et tenus à jour par le tiers
A.10.2.2	Surveillance et examen des services tiers	Mesure Les services, rapports et enregistrements fournis par les tiers doivent être régulièrement contrôlés et réexaminés, et des audits doivent être régulièrement réalisés.

A.10.2.3	Gestion des modifications dans les services tiers	Mesure Les changements effectués dans la prestation de service, comprenant le maintien et l'amélioration des politiques, procédures et mesures existant en matière de sécurité de l'information, doivent être gérés en tenant compte de la criticité des systèmes et processus de gestion concernés et de la réévaluation du risque
A.10.3 Planification et acceptation du système <i>Objectif:</i> Réduire le plus possible le risque de pannes du système.		
A.10.3.1	Dimensionnement	Mesure L'utilisation des ressources doit être surveillée et ajustée au plus près, et des projections doivent être faites sur les dimensionnements futurs pour assurer les performances requises par le système
A.10.3.2	Acceptation du système	Mesure Les critères d'acceptation doivent être fixés pour les nouveaux systèmes d'information, les nouvelles versions et les mises à niveau, et les tests adaptés du (des) système(s) doivent être réalisés au moment du développement et préalablement à leur acceptation
A.10.4 Protection contre les codes malveillants et mobile <i>Objectif:</i> Protéger l'intégrité des logiciels et de l'information		
A.10.4.1	Mesures contre les codes malveillants	Mesure Des mesures de détection, de prévention et de recouvrement pour se protéger des codes malveillants ainsi que des procédures appropriées de sensibilisation des utilisateurs doivent être mises en œuvre
A.10.4.2	Mesures contre le code mobile	Mesure Lorsque l'utilisation de code mobile est autorisée, la configuration doit garantir que le code mobile fonctionne selon une politique de sécurité clairement définie et tout code mobile non autorisé doit être bloqué
A.10.5 Sauvegarde <i>Objectif:</i> Maintenir l'intégrité et la disponibilité des informations et des moyens de traitement de l'information.		
A.10.5.1	Sauvegarde des informations	Mesure Des copies de sauvegarde des informations et logiciels doivent être réalisées et soumises régulièrement à essai conformément à la politique de sauvegarde convenue
A.10.6 Gestion de la sécurité des réseaux <i>Objectif:</i> Assurer la protection des informations sur les réseaux et la protection de l'infrastructure sur laquelle elles s'appuient.		

A.10.6.1	Mesures sur les réseaux	Mesure Les réseaux doivent être gérés et contrôlés de manière adéquate pour qu'ils soient protégés des menaces et pour maintenir la sécurité des systèmes et des applications utilisant le réseau, notamment les informations en transit
A.10.6.2	Sécurité des services réseau	Mesure Pour tous les services réseau, les fonctions réseau, les niveaux de service et les exigences de gestion doivent être identifiés et intégrés dans tout accord sur les services réseau, qu'ils soient fournis en interne ou en externe
A.10.7 Manipulation des supports <i>Objectif:</i> Empêcher la divulgation, la modification, le retrait ou la destruction non autorisé(e) d'actifs et l'interruption des activités de l'organisme		
A.10.7.1	Gestion des supports amovibles	Mesure Des procédures doivent être mises en place pour la gestion des supports amovibles
A.10.7.2	Mise au rebut des supports	Mesure Les supports qui ne servent plus doivent être mis au rebut de façon sûre, en suivant des procédures formelles.
A.10.7.3	Procédures de manipulation des informations	Mesure Des procédures de manipulation et de stockage des informations doivent être établies pour protéger ces informations d'une divulgation non autorisée ou d'un mauvais usage.
A.10.7.4	Sécurité de la documentation système	Mesure La documentation système doit être protégée contre les accès non autorisés
A.10.8 Echange des informations <i>Objectif:</i> Maintenir la sécurité des informations et des logiciels échangés au sein de l'organisme et avec une entité extérieure		
A.10.8.1	Politiques et procédures d'échange des informations	Mesure Des politiques, procédures et mesures d'échange formelles doivent être mises en place pour protéger les échanges d'informations liées à tous types d'équipements de télécommunication
A.10.8.2	Accords d'échange	Mesure Des accords doivent être conclus pour l'échange d'informations et de logiciels entre l'organisme et la partie externe.
A.10.8.3	Supports physiques en transit	Mesure Les supports contenant des informations doivent être protégés contre les accès non autorisés, le mauvais usage ou l'altération lors du transport hors des limites physiques de l'organisme
A.10.8.4	Messagerie électronique	Mesure Les informations liées à la messagerie

		électronique doivent être protégées de manière adéquate
A.10.8.5	Systèmes d'information d'entreprise	<i>Mesure</i> Des politiques et procédures doivent être élaborées et mises en œuvre pour protéger l'information liée à l'interconnexion de systèmes d'informations d'entreprise
A.10.9 Services de commerce électronique <i>Objectif:</i> Assurer la sécurité des services de commerce électronique, ainsi que leur utilisation sécurisée		
A.10.9.1	Commerce électronique	<i>Mesure</i> Les informations liées au commerce électronique transmises sur les réseaux publics doivent être protégées contre les activités frauduleuses, les litiges sur les contrats et la divulgation et la modification non autorisées
A.10.9.2	Transactions en ligne	<i>Mesure</i> Les informations liées aux transactions en ligne doivent être protégées pour empêcher la transmission incomplète, les erreurs d'acheminement, la modification non autorisée, la divulgation non autorisée, la duplication non autorisée du message ou la réémission.
A.10.9.3	Informations à disposition du public	<i>Mesure</i> L'intégrité des informations mises à disposition sur un système accessible au public doit être protégée pour empêcher toute modification non autorisée
A.10.10 Surveillance <i>Objectif:</i> Détecter les traitements non autorisés de l'information.		
A.10.10.1	Journaux d'audit	<i>Mesure</i> Les journaux d'audit, qui enregistrent les activités des utilisateurs, les exceptions et les événements liés à la sécurité doivent être produits et conservés pendant une période préalablement définie afin de faciliter les investigations ultérieures et la surveillance du contrôle d'accès
A.10.10.2	Surveillance de l'exploitation du système	<i>Mesure</i> Des procédures permettant de surveiller l'utilisation des moyens de traitement de l'information doivent être établies et les résultats des activités de surveillance doivent être réexaminés périodiquement
A.10.10.3	Protection des informations journalisées	<i>Mesure</i> Les équipements de journalisation et les informations journalisées doivent être protégés contre le sabotage et les accès non autorisés.
A.10.10.4	Journal administrateur et journal des opérations	<i>Mesure</i> Les activités de l'administrateur système et de

		l'opérateur système doivent être journalisées
A.10.10.5	Rapports d'anomalies	<i>Mesure</i> Les éventuels défauts doivent être journalisés et analysés et les mesures appropriées doivent être prises
A.10.10.6	Synchronisation des horloges	<i>Mesure</i> Les horloges des différents systèmes de traitement de l'information d'un organisme ou d'un domaine de sécurité doivent être synchronisées à l'aide d'une source de temps précise et préalablement définie
A.11 Contrôle d'accès		
A.11.1 Exigences métier relatives au contrôle d'accès		
<i>Objectif:</i> Maîtriser l'accès à l'information.		
A.11.1.1	Politique de contrôle d'accès	<i>Mesure</i> Une politique de contrôle d'accès doit être établie, documentée et réexaminée sur la base des exigences métier et de sécurité
A.11.2 Gestion des accès des utilisateurs		
<i>Objectif:</i> Contrôler l'accès des utilisateurs autorisés et empêcher les accès non autorisés aux systèmes d'information.		
A.11.2.1	Enregistrement des utilisateurs	<i>Mesure</i> Une procédure formelle d'inscription et désinscription des utilisateurs destinée à accorder et à supprimer l'accès à tous les systèmes et services d'information doit être définie.
A.11.2.2	Gestion des privilèges	<i>Mesure</i> L'attribution et l'utilisation des privilèges doivent être restreintes et contrôlées
A.11.2.3	Gestion du mot de passe utilisateur	<i>Mesure</i> L'attribution de mots de passe doit être réalisée dans le cadre d'un processus formel
A.11.2.4	Réexamen des droits d'accès utilisateurs	<i>Mesure</i> La direction doit réexaminer les droits d'accès utilisateurs à intervalles réguliers par le biais d'un processus formel.
A.11.3 Responsabilités de l'utilisateur		
<i>Objectif:</i> Empêcher l'accès d'utilisateurs non habilités et la compromission ou le vol d'informations et de moyens de traitement de l'information.		
A.11.3.1	Utilisation du mot de passe	<i>Mesure</i> Il doit être demandé aux utilisateurs de respecter les bonnes pratiques de sécurité lors de la sélection et de l'utilisation de mots de passe
A.11.3.2	Matériel utilisateur laissé sans surveillance	<i>Mesure</i> Les utilisateurs doivent s'assurer que tout matériel laissé sans surveillance est doté d'une protection appropriée.
A.11.3.3	Politique du bureau propre et de l'écran vide	<i>Mesure</i> Une politique du bureau propre doit être adoptée pour les documents papier et les supports de

		stockage amovibles, et une politique de l'écran vide doit également être adoptée pour les moyens de traitement de l'information
A.11.4 Contrôle d'accès réseau		
<i>Objectif:</i> Empêcher les accès non autorisés aux services disponibles sur le réseau		
A.11.4.1	Politique relative à l'utilisation des services en réseau	<i>Mesure</i> Les utilisateurs doivent avoir uniquement accès aux services pour lesquels ils ont spécifiquement reçu une autorisation
A.11.4.2	Authentification de l'utilisateur pour les connexions externes	<i>Mesure</i> Des méthodes d'authentification appropriées doivent être utilisées pour contrôler l'accès des utilisateurs distants
A.11.4.3	Identification des matériels en réseaux	<i>Mesure</i> L'identification automatique de matériels doit être considérée comme un moyen d'authentification des connexions à partir de lieux et matériels spécifiques
A.11.4.4	Protection des ports de diagnostic et de configuration à distance	<i>Mesure</i> L'accès physique et logique aux ports de diagnostic et de configuration à distance doit être contrôlé
A.11.4.5	Cloisonnement des réseaux	<i>Mesure</i> Les groupes de services d'information, d'utilisateurs et de systèmes d'information doivent être séparés sur le réseau.
A.11.4.6	Mesure relative à la connexion réseau	<i>Mesure</i> Pour les réseaux partagés, en particulier les réseaux qui s'étendent au delà des limites de l'organisme, la capacité de connexion réseau des utilisateurs doit être restreinte, conformément à la politique de contrôle d'accès et aux exigences relatives aux applications métier (voir 11.1)
A.11.4.7	Contrôle du routage réseau	<i>Mesure</i> Des mesures du routage des réseaux doivent être mises en œuvre afin d'éviter que les connexions réseau et les flux d'informations ne portent atteinte à la politique de contrôle d'accès des applications métier
A.11.5 Contrôle d'accès au système d'exploitation		
<i>Objectif:</i> Empêcher les accès non autorisés aux systèmes d'exploitation		
A.11.5.1	Ouverture de sessions sécurisées	<i>Mesure</i> L'accès aux systèmes d'exploitation doit être soumis à une procédure sécurisée d'ouverture de session.
A.11.5.2	Identification et authentification de l'utilisateur	<i>Mesure</i> Un identifiant unique et exclusif doit être attribué à chaque utilisateur et une technique d'authentification doit être choisie, permettant de vérifier l'identité déclarée par l'utilisateur

A.11.5.3	Système de gestion des mots de passe	<i>Mesure</i> Les systèmes qui gèrent les mots de passe doivent être interactifs et doivent fournir des mots de passe de qualité.
A.11.5.4	Emploi des utilitaires système	<i>Mesure</i> L'emploi des programmes utilitaires permettant de contourner les mesures d'un système ou d'une application doit être limité et contrôlé étroitement.
A.11.5.5	Déconnexion automatique des sessions inactives	<i>Mesure</i> Les sessions inactives doivent être déconnectées après une période d'inactivité définie
A.11.5.6	Limitation du temps de connexion	<i>Mesure</i> Les temps de connexion doivent être restreints afin d'apporter un niveau de sécurité supplémentaire aux applications à haut risque
A.11.6 Contrôle d'accès aux applications et à l'information		
<i>Objectif:</i> Empêcher les accès non autorisés aux informations stockées dans les applications		
A.11.6.1	Restriction d'accès à l'information	<i>Mesure</i> Pour les utilisateurs et le personnel chargé de l'assistance technique, l'accès aux informations et aux fonctions applicatives doit être restreint conformément à la politique de contrôle d'accès.
A.11.6.2	Isolement des systèmes sensibles	<i>Mesure</i> Les systèmes sensibles doivent disposer d'un environnement informatique dédié (isolé)
A.11.7 Informatique mobile et télétravail		
<i>Objectif:</i> Garantir la sécurité de l'information lors de l'utilisation d'appareils informatiques mobiles et d'équipements de télétravail.		
A.11.7.1	Informatique et communications mobiles	<i>Mesure</i> Une procédure formelle et des mesures de sécurité appropriées doivent être mises en place pour assurer une protection contre le risque lié à l'utilisation d'appareils informatiques et de communication mobiles
A.11.7.2	Télétravail	<i>Mesure</i> Une politique, des procédures et des programmes opérationnels spécifiques au télétravail doivent être élaborés et mis en œuvre
A.12 Acquisition, développement et maintenance des systèmes d'information		
A.12.1 Exigences de sécurité applicables aux systèmes d'information		
<i>Objectif:</i> Veiller à ce que la sécurité fasse partie intégrante des systèmes d'information		
A.12.1.1	Analyse et spécification des exigences de sécurité	<i>Mesure</i> Les exigences métier relatives aux nouveaux systèmes d'information ou les améliorations apportées aux systèmes d'information existants doivent spécifier les exigences de sécurité.
A.12.2 Bon fonctionnement des applications		
<i>Objectif:</i> Empêcher toute erreur, perte, modification non autorisée ou tout mauvais usage des		

informations dans les applications.		
A.12.2.1	Validation des données en entrée	<i>Mesure</i> Les données entrées dans les applications doivent être validées afin de vérifier si elles sont correctes et appropriées.
A.12.2.2	Mesure relative au traitement interne	<i>Mesure</i> Des contrôles de validation doivent être inclus dans les applications afin de détecter les éventuelles altérations de l'information dues à des erreurs de traitement ou des actes délibérés
A.12.2.3	Intégrité des messages	<i>Mesure</i> Les exigences permettant d'assurer l'authentification et la protection de l'intégrité des messages dans les applications doivent être identifiées, et des mesures appropriées doivent être identifiées et mises en œuvre
A.12.2.4	Validation des données en sortie	<i>Mesure</i> Les données de sortie d'une application doivent être validées pour assurer que le traitement des informations stockées est correct et adapté aux circonstances
A.12.3 Mesures cryptographiques <i>Objectif:</i> Protéger la confidentialité, l'authenticité ou l'intégrité de l'information par des moyens cryptographiques		
A.12.3.1	Politique d'utilisation des mesures cryptographiques	<i>Mesure</i> Une politique d'utilisation des mesures cryptographiques en vue de protéger l'information doit être élaborée et mise en œuvre
A.12.3.2	Gestion des clés	<i>Mesure</i> Une procédure de gestion des clés doit favoriser l'utilisation par l'organisme de techniques cryptographiques
A.12.4 Sécurité des fichiers système <i>Objectif:</i> Garantir la sécurité des fichiers système		
A.12.4.1	Mesure relative aux logiciels en exploitation	<i>Mesure</i> Des procédures doivent être mises en place pour contrôler l'installation du logiciel sur les systèmes en exploitation.
A.12.4.2	Protection des données système d'essai	<i>Mesure</i> Les données d'essai doivent être sélectionnées avec soin, protégées et contrôlées
A.12.4.3	Contrôle d'accès au code source du programme	<i>Mesure</i> L'accès au code source du programme doit être restreint
A.12.5 Sécurité en matière de développement et d'assistance technique <i>Objectif:</i> Garantir la sécurité du logiciel et des informations d'application.		
A.12.5.1	Procédures de contrôle des modifications	<i>Mesure</i> La mise en œuvre des modifications doit être contrôlée par le biais de procédures formelles.

A.12.5.2	Réexamen technique des applications après modification du système d'exploitation	<i>Mesure</i> Lorsque des modifications sont apportées aux systèmes d'exploitation, les applications critiques métier doivent être réexaminées et testées afin de vérifier l'absence de tout effet indésirable sur l'activité ou sur la sécurité.
A.12.5.3	Restrictions relatives à la modification des progiciels	<i>Mesure</i> La modification des progiciels ne doit pas être encouragée, et doit être limitée aux changements nécessaires. Un contrôle strict doit également être exercé sur ces modifications
A.12.5.4	Fuite d'informations	<i>Mesure</i> Toute possibilité de fuite d'informations doit être empêchée.
A.12.5.5	Externalisation du développement logiciel	<i>Mesure</i> Le développement logiciel externalisé doit être encadré et contrôlé par l'organisme
A.12.6 Gestion des vulnérabilités techniques <i>Objectif:</i> Réduire les risques liés à l'exploitation des vulnérabilités techniques ayant fait l'objet d'une publication		
A.12.6.1	Mesure relative aux vulnérabilités techniques	<i>Mesure</i> Toute information concernant toute vulnérabilité technique des systèmes d'information en exploitation doit être obtenue à temps, l'exposition de l'organisme aux dites vulnérabilités doit être évaluée et les actions appropriées doivent être entreprises pour traiter le risque associé
A.13 Gestion des incidents liés à la sécurité de l'information		
A.13.1 Remontée des événements et des failles liés à la sécurité de l'information <i>Objectif:</i> Garantir que le mode de notification des événements et failles liés à la sécurité de l'information permet la mise en œuvre d'une action corrective, dans les meilleurs délais.		
A.13.1.1	Remontée des événements liés à la sécurité de l'information	<i>Mesure</i> Les événements liés à la sécurité de l'information doivent être signalés, dans les meilleurs délais, par les voies hiérarchiques appropriées
A.13.1.2	Remontée des failles de sécurité	<i>Mesure</i> Il doit être demandé à tous les salariés, contractants et utilisateurs tiers des systèmes et services d'information de noter et de signaler toute faille de sécurité observée ou soupçonnée dans les systèmes ou services
A.13.2 Gestion des incidents liés à la sécurité de l'information et des améliorations <i>Objectif:</i> Garantir la mise en place d'une approche cohérente et efficace pour la gestion des incidents liés à la sécurité de l'information		
A.13.2.1	Responsabilités et procédures	<i>Mesure</i> Des responsabilités et des procédures doivent être établies, permettant de garantir une réponse rapide, efficace et pertinente en cas d'incident lié

		à la sécurité de l'information.
A.13.2.2	Exploitation des incidents liés à la sécurité de l'information déjà survenus	<i>Mesure</i> Des mécanismes doivent être mis en place, permettant de quantifier et surveiller les différents types d'incidents liés à la sécurité de l'information ainsi que leur volume et les coûts associés
A.13.2.3	Collecte de preuves	<i>Mesure</i> Lorsqu'une action en justice civile ou pénale est engagée contre une personne physique ou un organisme, à la suite d'un incident lié à la sécurité de l'information, les éléments de preuve doivent être recueillis, conservés et présentés conformément aux dispositions légales relatives à la présentation de preuves régissant la ou les juridiction(s) compétente(s).
A.14 Gestion de la continuité de l'activité		
A.14.1 Gestion de la continuité de l'activité d'un point de vue aspects de la sécurité de l'information <i>Objectif:</i> Empêcher les interruptions des activités de l'organisme, protéger les processus métier cruciaux des effets causés par les défaillances majeures des systèmes d'information ou par des sinistres et garantir une reprise de ces processus dans les meilleurs délais		
A.14.1.1	Intégration de la sécurité de l'information dans le processus de gestion du plan de continuité de l'activité	<i>Mesure</i> Un processus de continuité de l'activité dans l'ensemble de l'organisme doit être élaboré et géré, qui satisfait aux exigences en matière de sécurité de l'information requises pour la continuité de l'activité de l'organisme
A.14.1.2	Continuité de l'activité et appréciation du risque	<i>Mesure</i> Les événements pouvant être à l'origine d'interruptions des processus métier doivent être identifiés, tout comme la probabilité et l'impact de telles interruptions et leurs conséquences pour la sécurité de l'information
A.14.1.3	Élaboration et mise en œuvre des plans de continuité intégrant la sécurité de l'information	<i>Mesure</i> Des plans doivent être élaborés et mis en œuvre pour maintenir ou restaurer l'exploitation et assurer la disponibilité des informations au niveau et dans les délais requis suite à une interruption ou une panne affectant les processus métier cruciaux.
A.14.1.4	Cadre de la planification de la continuité de l'activité	<i>Mesure</i> Un cadre unique pour les plans de continuité de l'activité doit être géré afin de garantir la cohérence de l'ensemble des plans, de satisfaire de manière constante aux exigences en matière de sécurité de l'information et d'identifier les priorités en matière de mise à l'essai et de maintenance.

A.14.1.5	Mise à l'essai, gestion et réévaluation constante des plans de continuité de l'activité	<i>Mesure</i> Les plans de continuité de l'activité doivent être testés et mis à jour régulièrement afin de s'assurer qu'ils sont actualisés et efficaces
A.15 Conformité		
A.15.1 Conformité aux exigences légales <i>Objectif:</i> Eviter toute violation des obligations légales, statutaires, réglementaires ou contractuelles et des exigences de sécurité		
A.15.1.1	Identification de la législation en vigueur	<i>Mesure</i> Pour chaque système d'information et pour l'organisme, toutes les exigences légales, réglementaires et contractuelles en vigueur doivent être définies, documentées et mises à jour, ainsi que la procédure utilisée par l'organisme pour satisfaire à ces exigences.
A.15.1.2	Droits de propriété intellectuelle (DPI)	<i>Mesure</i> Des procédures appropriées doivent être mises en œuvre, visant à garantir la conformité avec les exigences légales, réglementaires et contractuelles concernant l'utilisation du matériel pouvant être soumis à des droits de propriété intellectuelle et l'utilisation des logiciels propriétaires
A.15.1.3	Protection des enregistrements de l'organisme	<i>Mesure</i> Les enregistrements importants doivent être protégés contre la perte, destruction et falsification conformément aux exigences légales, réglementaires et aux exigences métier
A.15.1.4	Protection des données et confidentialité des informations relatives à la vie privée	<i>Mesure</i> La protection et la confidentialité des données doivent être garanties, telles que l'exigent la législation ou les réglementations applicables, et les clauses contractuelles le cas échéant
A.15.1.5	Mesure préventive à l'égard du mauvais usage des moyens de traitement de l'information	<i>Mesure</i> Les utilisateurs doivent être dissuadés de toute utilisation de moyens de traitement de l'information à des fins illégales
A.15.1.6	Réglementation relative aux mesures cryptographiques	<i>Mesure</i> Des mesures cryptographiques doivent être prises conformément aux accords, lois et réglementations applicables.
A.15.2 Conformité avec les politiques et normes de sécurité et conformité technique <i>Objectif:</i> S'assurer de la conformité des systèmes avec les politiques et normes de sécurité de l'organisme.		
A.15.2.1	Conformité avec les politiques et les normes de sécurité	<i>Mesure</i> Les responsables doivent s'assurer de l'exécution correcte de l'ensemble des procédures de sécurité placées sous leur responsabilité en vue de garantir leur conformité avec les politiques

		et normes de sécurité.
A.15.2.2	Vérification de la conformité technique	<i>Mesure</i> La conformité des systèmes d'information avec les normes relatives à la mise en œuvre de la sécurité doit être vérifiée régulièrement
<i>A.15.3 Prises en compte de l'audit du système d'information</i> <i>Objectif:</i> Optimiser l'efficacité et réduire le plus possible l'interférence avec le/du processus d'audit du système d'information		
A.15.3.1	Contrôles de l'audit du système d'information	<i>Mesure</i> Les exigences d'audit et les activités impliquant des contrôles des systèmes en exploitation doivent être planifiées de manière précise et doivent être le résultat d'un accord afin de réduire le plus possible le risque de perturbations des processus métier
A.15.3.2	Protection des outils d'audit du système d'information	<i>Mesure</i> L'accès aux outils d'audit du système d'information doit être protégé afin d'empêcher tous mauvais usage ou compromission éventuels

Bibliographie

[**A. Ben Mouloud, 2011**] : Ali Ben Mouloud, M. Moez Yeddes, M. Mounir Arjdal, «*Mise en œuvre d'un système de management de la sécurité de l'information (SMSI) au sein de l'Ambassade du Royaume du Maroc à Tunis* », Mémoire Pour l'obtention d'un Diplôme de Mastère Professionnel, 2011.